

פרק 3 - מודל ה-AAA

11 שעות עיוני + 3 מעשי · שבועות 7-9

מטרות: מודל AAA · שרתי (ACS/ISE) · AAA + TACACS + RADIUS עם מפתחות מוצפנים
בבגרות: הגדרת שלושת השירותים, aaa new-model, RADIUS מול TACACS +

לפני שמתחילים - מה זו בכלל "הזדהות"? (למי שאין רקע)

כשאתם נכנסים לחשבון (מייל, בנק, נתב) קורים שלושה דברים שאנשים נוטים לבלבל - וזה בדיוק מה שמודל AAA מסדר: **הזדהות** (Authentication) - להוכיח התא ימ (שם משתמש + סיסמה). כמו להראות תעודת זהות. **הרשאה** (Authorization) - לקבוע ל רתום ה אחרי שנכנסת (לצפות בלבד? לשנות הכול?). כמו דרגת גישה בעבודה. **רישום** (Accounting) - לתעד תישע המ (מתי נכנסת, אילו פקודות הקלדת). כמו יומן מעקב. **למה מרכזי?** בלי מערכת מרכזית, כל נתב מחזיק רשימת משתמשים משלו. אם יש 50 נתבים ועובד עוזב - צריך למחוק אותו מ-50 מקומות. מודל AAA מאפשר "מקום אחד" שכל הנתבים שואלים אותו (שרת). זה כל הרעיון.

מושג שיחזור: שרת = מחשב מרכזי שנותן שירות (כאן: שירות "מי מורשה"). **לקוח** של השרת הזה = הנתב עצמו, ששואל את השרת "האם להכניס את המשתמש הזה?".

הערה על תכנית הלימודים

רשימת הנושאים של פרק 3 בתכנית הרשמית הועתקה בטעות מפרק 2. הפרק כאן בנוי לפי המטרות של פרק 3 - שהן גם בדיוק מה שהבגרות שואלת.

3.1 שלוש ה-A

עד עכשיו כל האימות היה **מקומי**: שם משתמש וסיסמה בקונפיג של כל נתב. זה לא מתרחב: 50 נתבים $\times$ 10 מנהלים = 500 חשבונות לתחזוק, ועובד שעוזב צריך להימחק מ-50 מקומות. AAA הוא המסגרת שפותרת את זה - בין אם המשתמשים מקומיים ובין אם בשרת מרכזי.

דוגמה	הגדרה (כפי שנדרש בבגרות)	השאלה שהוא עונה עליה	שירות
שם משתמש + סיסמה, כרטיס חכם, טביעת אצבע	זיהוי ואימות משתמשים	מי אתה?	Authentication (אימות)
רמה 15 או רק show; גישה ל-VLAN 10 בלבד; מותר reload?	ניהול הרשאות	מה מותר לך לעשות?	Authorization (הרשאה)
נכנס ב-08:12, הקליד reload ב-08:14, ניתק ב-08:15; 2GB תעבורה	רישום למעקב של פעולות המשתמש	מה עשית, מתי וכמה?	Accounting (רישום/חיוב)

שאלת תלמיד: "מה ההבדל בין Authentication ל-Authorization? זה נשמע אותו דבר"

המשל שעובד: שדה תעופה. **אימות** = בדיקת הדרכון בכניסה - מוודאים שאתה מי שאתה טוען. **הרשאה** = כרטיס הטיסה - גם אחרי שידוע מי אתה, מותר לך לעלות רק לטיסה שלך ולא לכל מטוס. Accounting = רישום הנוסעים - מי עלה, מתי, עם כמה מזוודות. אי אפשר לעשות הרשאה בלי אימות קודם, אבל אימות לבד לא אומר שמותר לך הכול.

גורמי אימות (Authentication factors)

- **משהו שאתה יודע** - סיסמה, PIN.
- **משהו שיש לך** - טלפון (OTP/SMS), טוקן, כרטיס חכם.
- **משהו שאתה** - ביומטריה: טביעת אצבע, פנים.

סיפור מהחיים: מנהל הרשת שפוטר ביום שלישי

בחברת שירותי אינטרנט בינונית פיטרו מנהל רשת. המנכ"ל ביקש מה-IT לבטל לו את הגישה". ה-IT מחק את חשבון ה-Windows שלו. אבל ב-40 הנתבים והמתגים היו חשבונות מקומיים (username בקונפיג) – שהוא עצמו יצר. שלושה ימים אחר כך, ב-2 בלילה, כל הנתבים "אבדו" את הקונפיג. אף אחד לא ידע מי עשה את זה – כי לא היה Accounting, ובלוג היה רק "admin עם AAA מבוסס שרת: לחיצה אחת ב-ISE הייתה מנתקת אותו מכל הציוד, וה-accounting היה מראה שם מלא, שעה ופקודה. זה בדיוק "למה. AAA".

3.2 שני מצבי AAA: מקומי ומבוסס-שרת

AAA מבוסס שרת (Server-based)	AAA מקומי (Local / Self-contained)	
בשרת מרכזי, (Cisco ISE / ACS, FreeRADIUS, Windows NPS)	בקונפיג של הנתב (username)	איפה המשתמשים
RADIUS או TACACS+ בין הנתב לשרת	-	פרוטוקול
ארגונים: ניהול מרכזי, מדיניות אחידה, לוג מרכזי	רשתות קטנות, גיבוי (fallback) כשהשרת לא זמין	מתאים ל

בטרמינולוגיה: הנתב/מתג/ASA שפונה לשרת נקרא NAS (Network Access Server) או AAA client. השרת מחזיק את מסד המשתמשים – או פונה בעצמו ל-Active Directory / LDAP.

3.3 AAA מקומי – הפקודות

```
! 1. הפעלת המודל – מרגע זה כל ה-lines משתמשות ב-AAA (ולא ב-login / login local)
R1(config)# aaa new-model
! 2. משתמש מקומי
R1(config)# username admin privilege 15 secret Admin-P@ss
! 3. רשימת שיטות אימות ברירת מחדל: local
R1(config)# aaa authentication login default local
! 4. רשימה בשם – למשל לקונסול: ללא אימות (זהירות!) או enable password
R1(config)# aaa authentication login CONSOLE-LIST local-case
R1(config)# line console 0
R1(config-line)# login authentication CONSOLE-LIST
```

הטעות המסוכנת ביותר בפרק

aaa new-model משנה מיד את התנהגות כל הקווים. אם הקלדתם אותה בלי משתמש מקומי ובלי aaa authentication login default (ברירת המחדל אחרי aaa new-model היא local, ואם אין username – אין כניסה). כלל ברזל: קודם username, אחר כך aaa new-model, ותמיד להשאיר חלון SSH אחד פתוח עד שבדקים בחלון שני.

שיטות אימות (methods) אפשריות ברשימה: local, local-case (תלוי רישיות), enable (סיסמת en-able), group radius, group tacacs+, group none (ללא אימות – רק לקונסול בבדיקות). ניתן לשרשר: הנתב מנסה את הראשונה; **רק אם היא לא זמינה** (שרת לא עונה) הוא עובר לבאה. תשובת "סיסמה שגויה" מהשרת אל גורמת למעבר לשיטה הבאה.

3.4 RADIUS מול TACACS+ – הטבלה שחייבים לדעת

	RADIUS	+TACACS
מי פיתח / תקן	תקן פתוח (IETF, RFC 2865)	Cisco (קנייני, אך מפורסם)

	RADIUS	+TACACS
שכבת תעבורה	UDP - פורטים 1812 (אימות) ו-1813 (accounting); ישן: 1645/1646	TCP - פורט 49
הצפנה	רק שדה הסיסמה מוצפן בבקשת הגישה (Access-Request); שם המשתמש ושאר המידע גלויים	כל גוף החבילה מוצפן (רק הכותרת גלויה)
הפרדת השירותים	אימות והרשאה משולבים בתגובה אחת (Access-Accept) מכיל גם את ההרשאות. לא ניתן לבצע הרשאה ללא אימות	שלושת השירותים נפרדים - ניתן לבצע אימות מול AD והרשאה מול +TACACS
הרשאה לכל פקודה	לא נתמך	נתמך - כל פקודה ש-המנהל מקליד נשלחת לאישור בשרת קיים, לרוב לרישום פקודות
Accounting	מפורט וחזק - פותח לחיוב (ISP)	קיים, לרוב לרישום פקודות
ריבוי פרוטוקולים	IP בלבד (בעיקר)	תומך גם ב-AppleTalk, NetBIOS וכו' (היסטורי)
שימוש אופייני	גישת משתמשים לרשת: Wi-Fi/802.1X, VPN מרחוק, דיאל-אפ	ניהול ציוד (device administration): מנהלי רשת שמתחברים לנתבים ולמתגים

בבגרות (שאלה 4) - נכון/לא נכון

1. RADIUS מצפין רק את הסיסמה כשהוא שולח "בקשת גישה" - **נכון**.
2. RADIUS מבצע אימות משתמשים ולא מתייחס לניהול הרשאות - **נכון** (במובן שאין הפרדה/הרשאה עצמאית; ההרשאות מגיעות רק כחלק מתשובת האימות).
3. TACACS+ משתמש רק ב-UDP - **לא נכון**. (TCP 49).
4. TACACS+ מספק שירות AAA - **נכון**.

שאלת תלמיד: "למה RADIUS על UDP אם TCP אמין יותר?"

RADIUS תוכנן ב-1991 לשרתי דיאל-אפ עם אלפי חיבורים; UDP קל, ללא לחיצת יד, והלקוח פשוט שולח שוב אם לא קיבל תשובה. TACACS+ בחר TCP כי הוא מנהל שיחה רב-שלבית (שאלה-תשובה-שאלה) ורוצה לדעת מיד אם השרת נפל. שניהם עובדים היום; ההבדל המעשי החשוב הוא ההצפנה והפרדת השירותים.

שיחה אופיינית - RADIUS

משתמש → NAS (נתב) → שרת RADIUS

1. המשתמש מקליד שם וסיסמה. 2. הנתב שולח Access-Request (הסיסמה מוצפנת עם ה-shared secret + MD5). 3. השרת עונה Access-Accept (עם VLAN - attributes, רמת הרשאה) / Access-Reject (נדרש גורם נוסף). 4. הנתב שולח Accounting-Request (start), ובסוף (stop).

שיחה אופיינית - TACACS+

שלוש שיחות נפרדות

Authentication: START → REPLY (GETUSER) → CONTINUE (שם) → REPLY (GETPASS) → RE-
 Authorization: REQUEST → CONTINUE (סיסמה) → REPLY (PASS/FAIL).
 Accounting: REQUEST (start/stop/watchdog) → REPLY. → SPONSE (PASS_ADD/FAIL).

סיפור מהחיים: למה ה-Wi-Fi באוניברסיטה שואל שם משתמש - ובבית קפה סיסמה

ברשת eduam (שפועלת גם באוניברסיטאות בישראל) סטודנט מחיפה מתחבר ל-Wi-Fi באוניברסיטה בברלין עם החשבון של הטכניון. איך? המחשב שולח שם משתמש ל-Access Point (802.1X), ה-AP

הוא רק Authenticator ומעביר את הבקשה לשרת RADIUS בברלין, שרואה "@technion.ac.il" ומעביר לשרת RADIUS בטכניון, שמאמת ומחזיר Access-Accept. שרת RADIUS אחד לא צריך להכיר את כל המשתמשים בעולם – רק לדעת למי להעביר. זו הסיבה ש-RADIUS הוא "פרוטוקול גישת המשתמשים לרשת", ו-TACACS+ נשאר לניהול הציוד.

3.5 Cisco ACS ו-ISE

ACS (Access Control Server) – שרת ה-AAA ההיסטורי של סיסקו (התכנית מזכירה אותו). תמך ב-RADIUS וב-TACACS+, עם GUI לניהול משתמשים, קבוצות ומדיניות. הוחלף ב-ISE (Identity Services Engine) – שרת מדיניות שעושה AAA, 802.1X, NAC, פרופילינג של מכשירים ו-BYOD. חלופות חינוכיות: FreeRADIUS, TACACS+ daemon, ו-RADIUS Windows NPS (על Windows Server). Packet Tracer יש שרת AAA מובנה שתומך בשניהם.

3.6 הגדרת AAA מבוסס-שרת ב-CLI

+TACACS

```
R1(config)# aaa new-model
! תחביר חדש (IOS 15+)
R1(config)# tacacs server ISE1
R1(config-server-tacacs)# address ipv4 10.0.0.5
R1(config-server-tacacs)# key T@cacK3y shared secret ! חייב להיות זהה בשרת
R1(config-server-tacacs)# single-connection ! חיבור TCP אחד לכל השיחות
R1(config-server-tacacs)# exit
! תחביר ישן (וב-Packet Tracer)
R1(config)# tacacs-server host 10.0.0.5 key T@cacK3y
! אימות: קודם TACACS+, ואם השרת לא זמין – מקומי
R1(config)# aaa authentication login default group tacacs+ local
```

RADIUS

```
R1(config)# radius server NPS1
R1(config-radius-server)# address ipv4 10.0.0.6 auth-port 1812 acct-port 1813
R1(config-radius-server)# key R@diusK3y
R1(config-radius-server)# exit
! תחביר ישן (וב-Packet Tracer)
R1(config)# radius-server host 10.0.0.6 key R@diusK3y
R1(config)# aaa authentication login default group radius local
```

קבוצת שרתים (server group) – כמה שרתים, ולפי סדר

```
R1(config)# aaa group server tacacs+ MY-TACACS
R1(config-sg-tacacs)# server name ISE1
R1(config-sg-tacacs)# server name ISE2
R1(config)# aaa authentication login default group MY-TACACS local
```

שאלת תלמיד: "מה זה ה-key? זה הסיסמה של המשתמש?"

לא. ה-key (shared secret) הוא סוד משותף בין הנתב לשרת, שמשמש להצפנת התקשורת ביניהם ולאימות שהנתב הוא באמת לקוח מורשה של השרת. סיסמאות המשתמשים נמצאות בשרת. שני מפתחות שונים לגמרי: המפתח בין הציוד לשרת, והסיסמה של האדם. "מפתחות מוצפנים" בתכנית הלימודים = ה-key הזה.

3.7 Authorization – הרשאות

```

! מי רשאי לקבל (EXEC) shell ובאיזו רמה
R1(config)# aaa authorization exec default group tacacs+ local
! אישור כל פקודה ברמה 15 מול השרת (TACACS+) (בלבד)
R1(config)# aaa authorization commands 15 default group tacacs+ local
! הרשאות לשירותי רשת (PPP, VPN) - בדרך כלל RADIUS
R1(config)# aaa authorization network default group radius
! שהפקודות בקונפיג עצמו (config mode) גם יאושרו
R1(config)# aaa authorization config-commands

```

שימו לב: אחרי `aaa authorization exec default group tacacs+ local`, אם השרת מחזיר 15 privilege - המשתמש נכנס ישירות ל-R1 בלי enable. זה נוח ומאובטח (אין סיסמת enable משותפת).

3.8 Accounting - רישום

```

! רישום התחלה וסיום של כל session
R1(config)# aaa accounting exec default start-stop group tacacs+
! רישום כל פקודה ברמה 15 - "מי הקליד reload"?
R1(config)# aaa accounting commands 15 default start-stop group tacacs+
! חיבורי רשת (VPN/PPP) - חיוב לפי זמן/נפח
R1(config)# aaa accounting network default start-stop group radius

```

אפשרויות: start-stop (רשומה בהתחלה ובסוף), stop-only (רק בסיום, עם סיכום), none.

3.9 802.1X AAA - לפורט של מתג (הצצה לפרק 6)

RADIUS משמש גם לאימות מכשירים לפני שמקבלים גישה לרשת: תקן IEEE 802.1X. שלושה תפקידים: Sup- plicant (המחשב/הטלפון), Authenticator (המתג או ה-Access Point - חוסם את הפורט עד לאימות), Authentication Server (RADIUS). ה-Authentication Server (RADIUS) הפרוטוקול בין ה-supplicant למתג: EAP over LAN (EAPOL); בין המתג ל-RADIUS. זה הבסיס ל-NAC (פרק 6) ול-WPA2-Enterprise.

```

S1(config)# aaa new-model
S1(config)# radius-server host 10.0.0.6 key R@diusK3y
S1(config)# aaa authentication dot1x default group radius
S1(config)# dot1x system-auth-control
S1(config)# interface f0/1
S1(config-if)# switchport mode access
S1(config-if)# authentication port-control auto
S1(config-if)# dot1x pae authenticator

```

3.10 בדיקה ופתרון תקלות

```

R1# show aaa sessions
R1# show aaa user all
R1# show tacacs
R1# show radius statistics
R1# test aaa group tacacs+ admin Admin-P@ss legacy ! בודק אימות מול השרת בלי להתחבר
R1# debug aaa authentication
R1# debug tacacs
R1# debug radius

```

תסמין	סיבה נפוצה
הנתב "נתקע" 10-20 שניות ואז מקבל את המשתמש המקומי	השרת לא נגיש (IP/ACL)/שירותי כבוי - fallback- ל-local עבד. בדקו ping לשרת ו-tacacs debug.

תסמין	סיבה נפוצה
Authentication failed" גם עם סיסמה נכונה	ה-key לא תואם בין הנתב לשרת; או שהשרת לא מכיר את ה-IP של הנתב כלקוח (AAA client). ב-Packet Tracer: בדקו ב-Server → AAA → Client Name/IP/Secret.
המשתמש נכנס אבל לא מקבל רמה 15	חסר aaa authorization exec attribute (shell:priv-lvl=15 לא מחזיר את ה- TACACS+; Service-Type / cisco-avpair ב-RADIUS).
הקונסול דורש אימות שרת ואין שרת	שכחו רשימה נפרדת לקונסול. תמיד: aaa authentication login CONSOLE local login authentication CONSOLE + con 0.

3.11 מדריך פקודות מרוכז - פרק 3

פקודה	תפקיד
aaa new-model	הפעלת AAA (בבגרות: "הפקודה שתגרום לנתב לעבוד עם מודל AAA")
aaa authentication login default group tacacs+ local	רשימת אימות: שרת ואז מקומי
+ aaa authentication login NAME ... login authentication NAME (ב-line)	רשימה בשם לקו ספציפי
tacacs/tacacs-server host IP key K server NAME	הגדרת שרת TACACS+
radius/radius-server host IP key K server NAME	הגדרת שרת RADIUS
aaa group server tacacs+ G	קבוצת שרתים
aaa authorization exec default ...	הרשאת shell
aaa authorization commands 15 default ...	הרשאה לכל פקודה
aaa accounting exec/commands/network default start-stop ...	רישום
debug aaa, show aaa sessions test aaa, authentication	בדיקה

3.12 תרגילים לתלמידים

תרגיל 1 - איזה A?

לכל משפט - Authentication, Authorization או Accounting: א. "המשתמש dana ניסתה להקליד configure terminal ונדחתה." ב. "החשבון של yossi נעול אחרי 3 ניסיונות." ג. "בדוח החודשי: 4,200 חיבורי VPN, ממוצע 38 דקות." ד. "המשתמש הזדהה עם טביעת אצבע." ה. "המורה יכולה לראות ציונים אבל לא לשנות."

א. Authorization ב. Authentication ג. Accounting ד. Authentication ה. Authorization

תרגיל 2 - מה יקרה?

נתב עם: aaa authentication login default group tacacs+ group radius local none. תארו את סדר הפעולות כאשר: (א) שרת ה-TACACS+ עונה "FAIL" (ב) שרת ה-TACACS+ לא עונה, ושרת ה-RADIUS עונה. Accept (ג) שני השרתים לא עונים ואין username בקונפיג.

(א) המשתמש נדחה – לא עוברים לשיטה הבאה אחרי דחייה. (ב) אחרי timeout של TACACS + הנתב פונה ל-RADIUS ומקבל את המשתמש. (ג) TACACS + timeout → RADIUS timeout → local (אין משתמשים → השיטה "לא זמינה", לא "דחייה") → none ⇒ המשתמש נכנס בלי אימות! לכן none מסוכן.

תרגיל 3 – בחירת פרוטוקול

לכל תרחיש בחרו RADIUS או TACACS + ונמקו במשפט:
א. אימות 2,000 תלמידים ל-Wi-Fi של בית הספר. ב. 5 מנהלי רשת שמנהלים 60 מתגים, ורוצים שמתמחה יוכל להקליד רק show. ג. ספק אינטרנט שמחייב לקוחות לפי נפח. ד. חברה שהרגולטור דורש ממנה תיעוד של כל פקודות קונפיגורציה.

א. RADIUS (גישת משתמשים, 802.1X). (הרשאה לכל פקודה). ג. RADIUS (accounting).
מפורט לנפח). ד. TACACS + (command accounting).

תרגיל 4 – תקלה

מנהל הקליד `aaa authentication login default group tacacs+` ואז `aaa new-model` (בלי `local`). השרת נפל. המנהל מתנתק. מה קרה, ואיך מתקנים?

ננעל בחוץ – אין שיטת גיבוי. תיקון: גישה פיזית לקונסול (אם לקונסול לא הוגדרה רשימה אחרת – גם הוא נעול!) ⇒ `password recovery` דרך `ROMMON (register 0x2142)`, ואז להוסיף `local` לרשימה ומשתמש מקומי. לקח: תמיד `local` ... בסוף, ורשימה נפרדת לקונסול.

3.13 שאלות בסגנון בגרות

שאלה 1

התאימו: (1) רישום הפקודות שהקליד המנהל (2) בדיקה אם מותר למשתמש להקליד (3) `reload` בדיקת שם משתמש וסיסמה. אפשרויות: Authentication / Authorization / Accounting.

(1) Accounting (2) Authorization (3) Authentication

שאלה 2

מנהל הגדיר: `aaa authentication login default group radius local`. שרתה-RADIUS זמין ומשיב "סיסמה שגויה". מה יקרה?

המשתמש יידחה. המעבר ל-`local` קורה רק כשרתה-RADIUS לא זמין (`timeout`), לא כשהוא דוחה.

שאלה 3

איזה פרוטוקול מתאים יותר לניהול ציוד רשת (`device administration`) עם אישור לכל פקודה, ומדוע?
TACACS + – מפריד בין אימות להרשאה ותומך בהרשאה לכל פקודה (`per-command authorization`);
RADIUS משלב אימות והרשאה ואינו תומך בכך.

שאלה 4

השלימו: פרוטוקול _____ משתמש ב-TCP פורט _____ ומצפין את _____ החבילה; פרוטוקול _____ משתמש ב-UDP פורטים _____ ומצפין רק את _____.

TACACS + • 49 • כל גוף • RADIUS • 1812/1813 • הסיסמה

שאלה 5

כתבו את הפקודות שמגדירות שרת TACACS + בכתובת 192.168.1.10 עם מפתח Key123, ואימות ברירת מחדל מולו עם גיבוי מקומי.

`aaa authentication tacacs-server host 192.168.1.10 key Key123`
`aaa new-model`

שאלה 6

ב-802.1X - מה תפקיד המתג?

Authenticator - חוסם את הפורט עד שה-supPLICANT מאומת מול שרת ה-RADIUS, ומתווך בין EAPOL ל-RADIUS.

3.14 מעבדה (3 שעות) - AAA ב-Packet Tracer

1. טופולוגיה: PC-Admin — SW — R1 — Server (AAA).
On; Client Name: → AAA → Services בשרת: R1, Client IP כתובת: R1, Secret Key123, ServerType: Tacacs (ואחר כך. Radius) הוסיפו User: admin / cisco123.
2. ב-R1: משתמש מקומי גיבוי, aaa new-model, key Key123, tacacs-server host ...
aaa authentication login default group tacacs+ local לפי פרק 2.
3. התחברו ב-SSH מה-PC עם admin/cisco123 - הצליח? כבו את שירות ה-AAA בשרת ונסו שוב -
ה-fallback למשתמש המקומי אמור לעבוד אחרי השהיה.
4. שנו את ה-secret בשרת בלבד - ראו את הכישלון; הריצו debug aaa authentication וקראו את הפלט.
5. חזרו על התרגיל עם RADIUS. השוו ב-Simulation mode את החבילות: ב-RADIUS רואים UDP; ב-TACACS+ רואים TCP.
6. הוסיפו רשימה בשם לקונסול עם local בלבד, וודאו שהקונסול לא פונה לשרת.

בנק שאלות שתלמידים שואלים - ותשובות מוכנות

שאלות נפוצות בפרק ה-AAA, עם תשובות מוכנות.

מושגי יסוד

ש: "אימות והרשאה נשמעים אותו דבר - מה ההבדל?"

ת: משל שדה התעופה: **אימות** = בדיקת הדרכון (מי אתה). **הרשאה** = כרטיס הטיסה (לאיזה מטוס מותר לך לעלות). קודם מוודאים מי אתה, ורק אז קובעים מה מותר לך. אי אפשר הרשאה בלי אימות.

ש: "ה-key בין הנתב לשרת - זו הסיסמה של המשתמש?"

ת: לא! ה-key הוא סוד משותף בין הנתב לשרת (מצפין ומאמת את הקשר ביניהם). סיסמאות המשתמשים נמצאות בשרת. שני דברים שונים לגמרי.

ש: "MFA ו-2FA זה אותו דבר?"

ת: 2FA (שני גורמים) הוא מקרה פרטי של MFA (רב-גורמי). העיקרון: שילוב גורמים מפינוש סיגוס - משהו שאתה יודע (סיסמה) + משהו שיש לך (טלפון) + משהו שאתה (טביעת אצבע). שתי סיסמאות אינן MFA.

מקומי מול שרת, ותקלות

ש: "אם שרת ה-AAA נופל, ננעלנו החוצה מכל הנתבים?"

ת: לא, אם הגדרתם נכון: רשימת השיטות מסתיימת ב-local (למשל local group tacacs+ ...). כשהשרת לא זמין, הנתב עובר אוטומטית לאימות מול משתמש מקומי. לכן דימת משאירים גיבוי מקומי.

ש: "מה קורה אם הקלדתי aaa new-model בטעות בלי משתמש מקומי?"

ת: אתם עלולים להינעל החוצה - כי מרגע הפקודה כל הקווים עוברים ל-AAA, ואם אין משתמש ואין רשימת ברירת מחדל, אין כניסה. כלל ברזל: קודם username, אחר כך aaa new-model, ולהשאיר חלון פתוח עד שבדקים בחלון שני.

ש: "אם השרת עונה 'סיסמה שגויה', הנתב עובר לאימות מקומי?"

ת: לא! מעבר לשיטה הבאה קורה רק כשהשרת נִימז אל (timeout). דחייה מפורשת מהשרת = המשתמש נדחה, בלי מעבר. זו נקודה שנשאלת בבגרות.

RADIUS מול TACACS+

ש: "אז איזה מהם 'יותר טוב', RADIUS או TACACS+?"
 ת: תלוי במשימה. לדיוצ'לוהינ (מנהלים שמתחברים לנתבים, עם אישור לכל פקודה) - TACACS+ עדיף. לתשרל סישמתשמ תשיג (Wi-Fi/802.1X, VPN) - RADIUS. בפועל ארגונים משתמשים בשניהם, כל אחד לתפקידו.

ש: "למה RADIUS על UDP אם TCP אמין יותר?"
 ת: RADIUS תוכנן ב-1991 לשרתי דיאל-אפ עם אלפי חיבורים; UDP קל ומהיר, והלקוח פשוט שולח שוב אם אין תשובה. TACACS+ בחר TCP כי הוא מנהל שיחה רב-שלבית ורוצה לדעת מיד אם השרת נפל. שניהם עובדים היום.

ש: "אומרים ש-RADIUS לא עושה הרשאה" - אבל הוא כן מחזיר הרשאות, לא?"
 ת: נכון, זו נקודה עדינה. RADIUS כן נושא attributes של הרשאה (VLAN, רמה) בתוך תשובת ה-Accept, אבל הוא בלשם אימות והרשאה בצעד אחד ואינו תומך באישור הדוקף לכל דרפנ כמו TACACS+. בבגרות "אינו מתייחס לניהול הרשאות" מתקבל כנכון במובן הזה.

ש: "מה זה 802.1X במשפט אחד?"
 ת: תקן שבו המתג/נקודת הגישה טרופה תא סימסוח עד שהמכשיר מאמת את עצמו מול שרת RADIUS. זה מה שמונע ממישהו לחבר מחשב לשקע ולקבל גישה, וזה הבסיס ל-Wi-Fi ארגוני (WPA2-Enterprise).

ש: "אפשר לחבר AAA ל-Active Directory של בית הספר?"
 ת: כן - זה בדיוק מה שעושים בארגונים. שרת ה-AAA (ISE/NPS/FreeRADIUS) מקבל את הבקשה מהנתב ומאמת מול ה-AD/LDAP כך המורים משתמשים באותם שם וסיסמה בכל מקום.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
AAA	מסגרת של שלושה שירותים: Authentication, Authorization, Accounting.
Authentication (אימות)	קביעת זהות המשתמש - מי אתה.
Authorization (הרשאה)	קביעת מה מותר למשתמש לעשות אחרי שאומת.
Accounting (רישום)	תיעוד פעולות המשתמש: מתי נכנס, אילו פקודות הקליד.
AAA מקומי	אימות מול מסד משתמשים בקונפיג של הנתב עצמו.
AAA מבוסס-שרת	אימות מול שרת מרכזי (ISE/ACS) בפרוטוקול RADIUS או TACACS+.
NAS / AAA client	ההתקן (נתב/מתג) שפונה לשרת ה-AAA בשם המשתמש.
RADIUS	פרוטוקול AAA פתוח, (1812/1813) UDP; מצפין רק את הסיסמה; לגישת משתמשים.
+TACACS	פרוטוקול AAA של סיסקו, TCP 49; מצפין את כל החבילה; מפריד שירותים; לניהול ציוד.
key / shared secret	סוד משותף בין הנתב לשרת המצפין ומאמת את הקשר ביניהם (לא סיסמת המשתמש).
ACS / ISE	שרתי ה-AAA של סיסקו (ACS) ישן, ISE מודרני.
aaa new-model	הפקודה שמפעילה את מסגרת ה-AAA בנתב.
method list	רשימת שיטות אימות מסודרת; עוברים לשיטה הבאה רק אם הקודמת לא זמינה.
802.1X	תקן שבו המתג/AP חוסם פורט עד לאימות מול שרת RADIUS.
Supplicant / Authenticator	ב-802.1X: המכשיר המבקש גישה (supplicant) והמתג שחוסם (authenticator).
MFA / 2FA	אימות רב-שלבי - שילוב גורמים מסוגים שונים (יודע/יש/הוא).